

شركة دايموند لوساطة التأمين
سياسة إدارة تقنية المعلومات
مايو 2025



Internal

DO NOT COPY

الاسم المسجل: شركة الوثيقة الماسية لوساطة التأمين
المركز الرئيسي: طريق الثمامة، الربيع، الرياض
مسؤول المستند: مدير إدارة الجودة والتطوير

المحتويات	
1	المقدمة
2	الهدف من السياسة
3	تعريف
4	نطاق تطبيق السياسة
5	القطاعات والإدارات ذات العلاقة
6	الكيانات ذات العلاقة
7	قواعد عامة
8	مسؤولية السياسة
9	التعاميم والتعليمات ذات العلاقة
10	حفظ السياسة
11	مخالفة السياسة



إدارة الجودة والتطوير Quality & Development Management

المادة (1): يحتوي هذا المستند على المعلومات المتعلقة بشركة الوثيقة الماسية (دايموند) ولا يجوز استخدام أو نسخ هذا المستند أو المعلومات التي يحتوي عليها كاملة أو جزءاً منها أو كشفه إلى الغير ما لم تقدم شركة الوثيقة الماسية (دايموند) موافقتها الكتابية على ذلك. لا يجوز تعديل أو حذف هذا التصريح المقيد في أي حالة من هذا المستند.



المادة (2): في حال وجود اختلاف بين النص العربي والإنجليزي فإن السيادة تكون للنص العربي.

معلومات السياسة				
سياسة إدارة تقنية المعلومات			عنوان السياسة	
مُحدّثة			حالة السياسة	
دليل سياسات وإجراءات تكنولوجيا المعلومات			عنوان السياسة السابقة	
30/10/2018			تاريخ السياسة السابقة	
1ITM0002			رقم المستند	
بعد مُرور سنتين من تاريخ اعتماد السياسة أو عند الضرورة			تاريخ المراجعة القادمة	
قسم خدمات الأعمال			مالك السياسة	
إدارة الجودة والتطوير			إعدت بواسطة	
مسؤولو القطاعات والإدارات الذين راجعوا السياسة ووافقوا عليها				
التوقيع	التاريخ	الأسم	الوظيفة	الإدارة
	29/07/2025	تركي عبد الله العبدلي	مدير إدارة الإلزام والامتثال	الإدارة الرقابية
	29/07/2025	شادن سلطان العتيبي	مدير إدارة الجودة والتطوير	رئيس مراجعة السياسات
اعتماد السياسة				
	29/07/2025	بدر سعد الشايع	العضو المنتدب	الإدارة العليا
حالة التداول		اسم المستند	رقم المستند	نوع المستند
داخلي		نموذج توثيق مشاركة خارجية للمعلومات	1QDM-FRM-80	نموذج



إدارة الجودة والتطوير

Quality & Development Management

1. المقدمة:

1.1 تُعد سياسة إدارة تقنية المعلومات جزءاً أساسياً في دعم عمليات الشركة، وتحقيق الكفاءة التشغيلية، وضمان استمرارية الأعمال. ومع تطور التحديات الرقمية والمخاطر التقنية، أصبح من الضروري اعتماد سياسة شاملة لإدارة تقنية المعلومات، تنظم كافة الجوانب المرتبطة بالبنية التحتية، أمن المعلومات، البرمجيات، الأجهزة، الخدمات التقنية، وإدارة الوصول، بما يضمن الحوكمة، الحماية، والامتثال التنظيمي.

2. الهدف من السياسة:

2.1 تثق شركة الوثيقة الماسية لوساطة التأمين (ويشار إليها فيما يلي بـ "دايموند") في أن الهدف من هذه السياسة هو وضع الإطار التنظيمي والإجرائي لإدارة جميع أنشطة تقنية المعلومات داخل الشركة، من خلال تحديد الأدوار، وتوزيع المسؤوليات، وتطبيق الضوابط التقنية والأمنية اللازمة، بما يضمن سلامة الأنظمة، سرية البيانات، تكامل العمليات التقنية، وامتثال الشركة للضوابط الصادرة من الجهات الرقابية والتنظيمية ذات العلاقة.

2.2 كما تهدف السياسة إلى ضمان الاستخدام الأمثل للموارد التقنية وتحقيق أعلى مستويات الكفاءة والجودة والاستمرارية في تقديم الخدمات.

3. تعاريف:

- 3.1 دايموند: شركة الوثيقة الماسية لوساطة التأمين.
- 3.2 الشركة: شركة الوثيقة الماسية لوساطة التأمين، ويشمل هذا التعريف كافة فروعها وكياناتها التابعة.
- 3.3 إدارة تقنية المعلومات: الجهة المسؤولة عن تخطيط وتنفيذ وصيانة وتشغيل البنية التحتية الرقمية للشركة، وضمان أمن وكفاءة الأنظمة التقنية المستخدمة.
- 3.4 البنية التحتية التقنية: تشمل جميع الخوادم، الشبكات، أجهزة الحاسب، معدات الاتصالات، ومرافق مراكز البيانات المستخدمة في تشغيل أنظمة الشركة.
- 3.5 الأصل التقني: أي جهاز أو أداة تقنية تُستخدم ضمن بيئة العمل كجزء من أنظمة المعلومات، وتشمل الحواسيب، الطابعات، أجهزة البصمة، الكاميرات، الخوادم، والموجهات.
- 3.6 سجل الأصول التقنية: قاعدة بيانات مركزية تحتوي على معلومات تفصيلية محدثة عن جميع الأصول التقنية المملوكة للشركة.
- 3.7 البرمجيات الإدارية: جميع البرامج والتطبيقات التقنية المستخدمة لتشغيل وإدارة العمليات الإدارية داخل الشركة، سواء كانت مطورة داخلياً أو مزودة من طرف ثالث.
- 3.8 الامتثال البرمجي: الالتزام باستخدام البرمجيات المرخصة والمعتمدة فقط، وفقاً للأنظمة والتعليمات التقنية والتنظيمية.
- 3.9 نظام التحكم في الوصول (NAC): آلية تقنية تمنع اتصال أي جهاز غير مصرح به بشبكة الشركة.
- 3.10 الأنظمة الأمنية (SIEM/IDS): أنظمة تحليل ومراقبة تسجل وتكشف عن الأنشطة المشبوهة داخل الشبكة التقنية.
- 3.11 النسخ الاحتياطي: عملية نسخ البيانات والمعلومات بشكل دوري للاحتفاظ بنسخة آمنة لاسترجاعها في حال حدوث خلل أو فقد للمعلومات الأصلية.
- 3.12 التشفير (Encryption): آلية حماية تُستخدم لتحويل البيانات إلى صيغة غير مفهومة إلا للأطراف المخولة، باستخدام خوارزميات مثل AES-256.
- 3.13 التحقق الثنائي (FA2): آلية أمنية تتطلب خطوتين لتأكيد هوية المستخدم، مثل كلمة المرور ورمز مؤقت عبر الجوال.
- 3.14 الحادث الأمني: أي خلل أو نشاط غير معتاد يهدد سرية أو سلامة أو توفر المعلومات الإدارية، كالتسريب، التعديل غير المصرح به، أو الاختراق.
- 3.15 DMS: نظام إدارة الوثائق الإلكتروني المعتمد في الشركة لتوثيق وأرشفة الوثائق والمستندات الرسمية.
- 3.16 BCP / DRP: خطتي استمرارية الأعمال واستعادة البيانات المعتمدتين لضمان استمرارية التشغيل في حال الطوارئ أو الكوارث.
- 3.17 مالك المعلومة: الشخص أو الجهة المخولة رسمياً داخل كل إدارة لتصنيف المعلومات وحمايتها والموافقة على مشاركتها.
- 3.18 المستخدم النهائي: أي موظف أو متعاون مُخول باستخدام الأنظمة التقنية وأجهزة الشركة لأداء مهامه المهنية.
- 3.19 المزود التقني الخارجي: أي جهة خارجية تقدم خدمات تقنية للشركة بموجب عقد رسمي.
- 3.20 المعلومات الإدارية: جميع البيانات والمستندات والوثائق الرقمية أو الورقية الناتجة عن عمليات الشركة اليومية.
- 3.21 بيانات شخصية: أي معلومات قابلة للتعرف على هوية فرد معين مثل الاسم، رقم الهوية، رقم الجوال، أو البريد الإلكتروني.

3.22 الأنظمة التنظيمية: تشمل الأنظمة الصادرة عن هيئة التأمين، هيئة الاتصالات، سدايا، وهيئة الأمن السيبراني وغيرها من الجهات الرسمية.

4. نطاق تطبيق السياسة :

4.1 تسري هذه السياسة على جميع أنظمة وأصول تقنية المعلومات في الشركة، وتشمل كافة الأجهزة، الخوادم، الشبكات، البرمجيات، أنظمة الاتصالات، البريد الإلكتروني، الحسابات التقنية، والمستخدمين المعتمدين. كما تشمل جميع الموظفين ومزودي الخدمات المتعاملين مع البيئة التقنية.

5. القطاعات والإدارات ذات العلاقة:

5.1 إدارة تقنية المعلومات، قسم الأمن السيبراني إدارة الالتزام والامتثال، إدارة الجودة والتطوير، إدارة الموارد البشرية و كافة الإدارات التشغيلية التي تعتمد على الأنظمة التقنية في أداء مهامها.

6. الكيانات ذات العلاقة:

6.1 كافة الكيانات المملوكة بالكامل إلى شركة دايمنود.

6.2 الجهات التنظيمية المشرفة على القطاع (هيئة التأمين، هيئة الأمن السيبراني)

7. قواعد عامة:

7.1 إدارة البنية التحتية والأصول التقنية

7.1.1 يجب شراء جميع الأجهزة والخوادم المستخدمة في تخزين أو معالجة المعلومات الإدارية من موردين معتمدين، وتُطبق مواصفاتها الحد الأدنى من المعايير الفنية المعتمدة في الشركة.

7.1.2 يُلزم بتسجيل كل أصل تقني في سجل الأصول التقنية، ويجب أن يتضمن السجل: الرقم التسلسلي، الفئة، الطراز، الجهة المالكة، المستخدم الفعلي، تاريخ الاستلام، والموقع الحالي.

7.1.3 يجب تحديث سجل الأصول دوريًا كل 6 أشهر على الأقل، ويُلزم بالإبلاغ الفوري عند حدوث نقل، فقدان، أو عطل في أي من الأصول.

7.1.4 يجب محو البيانات بالكامل باستخدام أدوات معتمدة قبل إتلاف الأصول التقنية. يُمنع التخلص من الأصول إلا عبر جهة مرخصة وفقًا للسياسات البيئية والتنظيمية.

7.1.5 يُلزم بتوثيق كل عملية نقل أو حركة للأصول في سجل حركة مستقل، يتضمن بيانات دقيقة حول الجهة المستلمة، حالة الأصل، التاريخ، واسم المسؤول عن التسليم والاستلام.

7.2 الشبكات والاتصالات:

7.2.1 يُمنع ربط أي أجهزة إضافية أو إنشاء شبكات فرعية أو نقاط وصول دون إذن مكتوب من مدير إدارة تقنية المعلومات.

7.2.2 يجب تفعيل أنظمة المراقبة المستمرة للشبكة باستخدام أدوات (NAC / IDS / SIEM) لكشف أي نشاط غير اعتيادي أو جهاز غير مصرح به.

7.2.3 يجب الاحتفاظ بسجلات الوصول الشبكي (Logs) لمدة لا تقل عن 12 شهرًا، مع حماية السجلات من الحذف أو التلاعب.

7.2.4 يُطبق نظام التصنيف الداخلي للشبكات (مثل: شبكة مفتوحة، شبكة مقيدة، شبكة حساسة) مع ضبط صلاحيات كل فئة وفقًا لمبدأ الحد الأدنى من الامتيازات.

7.2.5 يُلزم باستخدام نظام التحكم في الدخول إلى الشبكة (NAC) لحظر أي جهاز لم يتم تسجيله مسبقًا ضمن قائمة الأصول المعتمدة.

7.3 البرمجيات والتطبيقات الإدارية:

7.3.1 لا يجوز تثبيت أو تحميل أي تطبيق أو برنامج إلا بعد الحصول على موافقة مكتوبة من مدير إدارة تقنية المعلومات.

7.3.2 يجب أن تكون جميع البرمجيات الإدارية مرخصة وموثقة في سجل التراخيص، ويُشترط توثيق تاريخ الشراء، فترة الترخيص، الجهة المزودة، وتاريخ التجديد القادم.

7.3.3 يُلزم باستخدام نظام آلي لمراقبة الامتثال البرمجي، لرصد استخدام البرمجيات غير المرخصة أو المشبوهة، على أن تُرسل تقارير الامتثال شهريًا إلى مدير الأمن السيبراني.

7.3.4 يُعد أي استخدام غير مصرح به للبرمجيات أو تثبيت من مصادر غير معتمدة مخالفة صريحة للسياسة ويُحاسب عليها الموظف وفقاً للإجراءات التأديبية.

7.4 الحسابات والصلاحيات:

7.4.1 يجب تخصيص حساب مستخدم فريد لكل موظف يتعامل مع أنظمة المعلومات الإدارية، مع ربطه مباشرة بدليل الصلاحيات المعتمد.

7.4.2 يُلزم بتحديث ومراجعة صلاحيات المستخدمين كل 3 أشهر بالتعاون بين الموارد البشرية وتقنية المعلومات.

7.4.3 يجب حذف أو تعليق صلاحيات الدخول فوراً عند انتهاء علاقة الموظف بالشركة أو تغيير مهامه، ولا يُسمح بالإبقاء على أي حساب غير نشط لأكثر من 30 يوماً دون مبرر رسمي.

7.5 أمن البريد الإلكتروني والإنترنت:

7.5.1 يُلزم باستخدام البريد الإلكتروني المؤسسي فقط لأغراض العمل الرسمي، ويُمنع استخدامه للتسجيل في خدمات خارجية غير مصرح بها.

7.5.2 يُراقب استخدام البريد الإلكتروني والإنترنت عبر أنظمة حماية ذكية، ويجب إعداد تقارير تحليل الأنشطة المشبوهة بشكل شهري.

7.5.3 يجب الإبلاغ عن أي بريد إلكتروني مشبوه أو محاولات تصيد فوراً إلى فريق الدعم الفني، ولا يُسمح للمستخدمين بفتح مرفقات من مصادر غير معروفة.

7.6 النسخ الاحتياطي واستعادة البيانات:

7.6.1 يجب تنفيذ نسخ احتياطي دوري لجميع المعلومات الإدارية الإلكترونية المخزنة على خوادم الشركة، وفق جدول زمني يومي على الأقل.

7.6.2 يُلزم بتخزين النسخ الاحتياطية في موقع منفصل وآمن يُراعى فيه توفر أنظمة الحماية البيئية (الحرارة، الرطوبة، الحريق).

7.6.3 يجب تشفير جميع النسخ الاحتياطية باستخدام خوارزميات تشفير قوية (AES-256 على الأقل)، لضمان حماية البيانات من الوصول غير المصرح به.

7.6.4 يجب اختبار قدرة استعادة البيانات شهرياً من النسخ الاحتياطية لضمان جاهزية النظام في حالات الطوارئ.

7.6.5 يُمنع استخدام وسائط خارجية محمولة (مثل USB) لتنفيذ النسخ الاحتياطي إلا في حالات الضرورة، وبعد الحصول على موافقة خطية من مشرف تقنية المعلومات.

7.6.6 يجب أن تشمل خطة النسخ الاحتياطي بيانات البريد الرسمي، محاضر الاجتماعات، قرارات الإدارة العليا، وقواعد البيانات الإدارية.

7.7 حماية البريد الإلكتروني الرسمي:

7.7.1 يجب استخدام البريد الإلكتروني الرسمي (dib.sa@) فقط للأغراض المهنية المتعلقة بالعمل الإداري.

7.7.2 يُلزم بعدم مشاركة محتوى البريد مع أطراف خارجية دون موافقة مسبقة من الجهة المالكة للمعلومة.

7.7.3 يُمنع استخدام البريد الإلكتروني الرسمي للتسجيل في مواقع أو خدمات غير مرتبطة بمصالح الشركة.

7.7.4 يجب تفعيل خاصية التحقق الثنائي (FA2) لجميع حسابات البريد الإلكتروني الإداري.

7.7.5 تُراجع سجلات الدخول للبريد الإلكتروني شهرياً من قبل مسؤول الأمن السيبراني، وتُوثق أي محاولة دخول مشبوهة.

7.8 إدارة الحوادث الأمنية المرتبطة بالمعلومات الإدارية:

7.8.1 يجب الإبلاغ الفوري عن أي فقد، تسريب، تعديل غير مصرح به، أو اشتباه في اختراق للمعلومات الإدارية، وذلك خلال ساعة واحدة من الاكتشاف.

7.8.2 يُلزم كل موظف برفع بلاغ رسمي عبر نظام إدارة الحوادث الداخلية، مع تحديد نوع الحادث، موقعه، وتوقيته.

7.8.3 تُعد تقارير تحليل السبب الجذري للحوادث من قبل مسؤول الأمن السيبراني بالتعاون مع الإدارة المالكة للمعلومة، ويُقدّم تقرير رسمي للإدارة التنفيذية خلال 48 ساعة.

7.8.4 تُحتفظ سجلات الحوادث التقنية في ملف مشفّر ضمن أرشيف الأمن السيبراني لمدة لا تقل عن 5 سنوات.

7.8.5 تُنفذ تمارين محاكاة نصف سنوية لاختبار جاهزية استجابة الشركة لحوادث المعلومات الإدارية.

7.9 التوثيق والمراجعة:

- 7.9.1 يجب على جميع الإدارات توثيق المعلومات الإدارية الصادرة والواردة باستخدام النظام الإلكتروني المعتمد لإدارة الوثائق (DMS).
- 7.9.2 يُلزم بحفظ الوثائق الإدارية المهمة مثل محاضر الاجتماعات، المراسلات الرسمية، قرارات الإدارة، وخطط العمل في مجلدات مؤرشفة بأسماء واضحة وتواريخ معتمدة.
- 7.9.3 تُحدّد فترة الاحتفاظ حسب نوع الوثيقة:
- 7.9.3.1 وثائق تنظيمية: 10 سنوات
- 7.9.3.2 مراسلات تشغيلية: 5 سنوات
- 7.9.3.3 نماذج يومية: سنتان
- 7.9.4 يُمنع إتلاف أو حذف أي وثيقة إدارية قبل انتهاء المدة المحددة لها، إلا بموافقة مكتوبة من مدير تقنية المعلومات والمدير المعني.
- 7.9.5 تُنفذ عملية إتلاف الوثائق إلكترونياً باستخدام أدوات حذف نهائي، وتوثق ضمن سجل الإتلاف الإداري.
- 7.10 التدريب والتوعية:
- 7.10.1 يجب على إدارة تقنية المعلومات، بالتعاون مع إدارة الموارد البشرية، تنفيذ برامج توعوية دورية لتعريف الموظفين بمسؤولياتهم تجاه حماية المعلومات الإدارية.
- 7.10.2 يُلزم بعقد دورة توجيهية جديدة لكل موظف ينضم حديثاً إلى الشركة، تتضمن شرحاً مفصلاً حول سياسات التعامل مع الوثائق والمعلومات الإدارية.
- 7.10.3 يجب تنفيذ ورش عمل داخلية نصف سنوية تغطي المواضيع التالية على الأقل:
- 7.10.3.1 أمن المعلومات الإدارية
- 7.10.3.2 طرق تصنيف المعلومات
- 7.10.3.3 ضوابط التوثيق والحفظ
- 7.10.3.4 آلية الإبلاغ عن الحوادث
- 7.10.4 يُطلب من جميع الموظفين التوقيع على إقرار خطي بالاطلاع والالتزام بسياسة إدارة المعلومات الإدارية، ويُحفظ الإقرار ضمن ملفهم الوظيفي.
- 7.10.5 تُقاس فعالية البرامج التدريبية عبر استبيانات دورية، ويُعد تقرير سنوي لعرض نسبة الوعي ومستوى الالتزام.
- 7.11 الامتثال التنظيمي والتشريعي:
- 7.11.1 يجب أن تلتزم جميع العمليات المرتبطة بإدارة المعلومات الإدارية بالتعليمات الصادرة عن الجهات الرقابية التالية:
- 7.11.1.1 الهيئة العامة للرقابة الإدارية ومكافحة الفساد
- 7.11.1.2 هيئة التأمين السعودية
- 7.11.1.3 الهيئة الوطنية للأمن السيبراني (NCA)
- 7.11.1.4 هيئة الاتصالات والفضاء والتقنية (CST)
- 7.11.1.5 سدايا (SDAIA) في ما يخص حماية البيانات الشخصية
- 7.11.2 يُلزم بتحديث السياسة فور صدور تعليمات جديدة تؤثر على طريقة جمع أو حفظ أو تداول المعلومات الإدارية.
- 7.11.3 تُراجع مدى مطابقة الممارسات للمتطلبات التشريعية سنوياً من قبل إدارة الأمن السيبراني، وتُرفع التوصيات إلى الإدارة العليا.
- 7.11.4 يجب أن تشمل العقود مع الجهات الخارجية بنوداً واضحة حول الامتثال للأنظمة المعمول بها في المملكة العربية السعودية.
- 7.12 الربط مع مزودي الخدمات التقنية:
- 7.12.1 يُمنع استخدام أي نظام أو تطبيق خارجي لمعالجة أو تخزين المعلومات الإدارية إلا بعد اعتماده رسمياً من إدارة تقنية المعلومات.
- 7.12.2 يجب على كافة مزودي الخدمات التقنية توقيع اتفاقية مستوى خدمة (SLA) تتضمن بنوداً واضحة حول حماية البيانات، التوافر، وسرعة الاستجابة.
- 7.12.3 تُراجع عقود مزودي الخدمات سنوياً للتأكد من استمرارية الالتزام بنود السرية والامتثال الأمني.
- 7.12.4 يُشترط أن يكون لكل مزود بوابة دعم فني نشطة، وتُتابع البلاغات عبر نظام تذاكر رسمي يُراقب من قبل تقنية المعلومات.
- 7.12.5 تُمنح صلاحيات الدخول لممثلي المزودين وفقاً لمبدأ أقل صلاحية، وتُلغى فور انتهاء التعاقد.
- 7.13 الحوكمة والمساءلة:

- 7.13.1 يجب تحديد "مالكي المعلومات الإدارية" في كل إدارة، وتوثيق مسؤولياتهم في تصنيف، مراجعة، واعتماد تداول الوثائق الصادرة عن إدارتهم.
- 7.13.2 يُلزم مالك المعلومة بإبلاغ إدارة تقنية المعلومات بأي تغيير في مستوى سرية المعلومات أو نطاق استخدامها.
- 7.13.3 يجب على مشرف تقنية المعلومات تنفيذ مراجعة ربع سنوية لسجلات الوصول والتعديلات على الوثائق الإدارية ذات الطابع الحساس.
- 7.13.4 تُعد إدارة الأمن السيبراني تقارير امتثال دورية تشمل نسب الالتزام، الثغرات المرصودة، وسلوك المستخدمين، وتُعرض على لجنة الأمن المعلوماتي.
- 7.13.5 تُطبق إجراءات محاسبة صارمة بحق كل موظف يُثبت إهماله أو تسببه في خرق هذه السياسة، وفق نظام العمل والجزاءات الداخلية.
- 7.14 خطة استمرارية الأعمال واستعادة البيانات (Business Continuity and Recovery):
- 7.14.1 يجب على إدارة تقنية المعلومات بالتنسيق مع إدارة المخاطر وضع خطة استمرارية أعمال (BCP) وخطة استعادة بيانات (DRP) تغطي جميع الأنظمة والبيانات الإدارية الحيوية.
- 7.14.2 يُلزم بتحديث ومراجعة هذه الخطط بشكل سنوي أو عند حدوث تغييرات تنظيمية أو تقنية تؤثر على استمرارية الأعمال.
- 7.14.3 يجب تنفيذ محاكاة لاختبار فعالية خطط الاستمرارية مرتين في السنة على الأقل، وتوثيق النتائج والإجراءات التصحيحية.
- 7.14.4 تُحتفظ نسخ محدثة من خطط الاستمرارية والاسترجاع في موقع إلكتروني محمي ونسخة ورقية في مكان آمن مادياً.
- 7.15 التوعية والتدريب الأمني للموظفين:
- 7.15.1 يُلزم جميع الموظفين الذين يتعاملون مع المعلومات الإدارية بحضور تدريب سنوي حول حماية البيانات، أمن المعلومات، وسياسات الشركة ذات العلاقة.
- 7.15.2 يجب أن يشمل التدريب موضوعات: سرية المعلومات، التعامل مع الوثائق، الإبلاغ عن الحوادث، واستخدام الأنظمة.
- 7.15.3 يجب تقييم فعالية التدريب من خلال اختبار معرفي بعد كل دورة تدريبية، وتوثيق نتائج التقييم.
- 7.15.4 تُنظم إدارة تقنية المعلومات حملات توعية ربع سنوية تشمل نشرات بريدية، ملصقات داخلية، أو ورش عمل قصيرة.
- 7.16 إدارة النماذج والوثائق الرسمية:
- 7.16.1 يجب أن يتم اعتماد جميع النماذج الإدارية المستخدمة في الشركة من الإدارة التنفيذية وتحديثها حسب الحاجة التشغيلية.
- 7.16.2 تُرقم جميع النماذج برمز معرفية (Code) وتعتمد بصيغ إلكترونية داخل النظام المعتمد لإدارة الوثائق (DMS).
- 7.16.3 يُمنع استخدام أي نموذج إداري لم يتم اعتماده رسمياً، ويُحاسب أي موظف يستخدم نماذج قديمة أو غير رسمية.
- 7.16.4 تُراجع النماذج المعتمدة سنوياً لضمان مواءمتها مع التغيرات التشغيلية أو التنظيمية.
- 7.17 مراقبة الامتثال والتدقيق الدوري:
- 7.17.1 يجب على إدارة الأمن السيبراني بالتعاون مع إدارة تقنية المعلومات إجراء تدقيق ربع سنوي على مدى الالتزام بسياسة إدارة المعلومات الإدارية.
- 7.17.2 يُعد تقرير تفصيلي عن نتائج التدقيق، يشمل الثغرات والمخالفات ومقترحات التحسين، ويُرفع إلى المدير التنفيذي.
- 7.17.3 تُحفظ تقارير التدقيق في سجل الامتثال وتُراجع من قبل إدارة المخاطر والامتثال.
- 7.17.4 يُلزم كل قسم بتقديم خطة تصحيحية لأي مخالفة يتم رصدها ضمن مهلة لا تتجاوز 15 يوماً من تاريخ التقرير.
- 7.18 إنهاء العلاقة الوظيفية ونقل الموظفين:
- 7.18.1 يجب على إدارة الموارد البشرية إخطار إدارة تقنية المعلومات قبل إنهاء خدمة أي موظف أو نقله إلى قسم آخر بما لا يقل عن 3 أيام عمل.
- 7.18.2 يُلزم بإلغاء صلاحيات الوصول إلى الأنظمة والملفات الإدارية في نفس يوم الخروج الوظيفي، وتشمل الحسابات، البريد الإلكتروني، وأنظمة المستندات.
- 7.18.3 في حالة نقل الموظف إلى قسم آخر، يجب إعادة تقييم صلاحياته حسب مهامه الجديدة، وتوثيق التعديلات في سجل إدارة الوصول.
- 7.18.4 تُسجل جميع العمليات المتعلقة بإلغاء أو تعديل الصلاحيات ضمن سجل رسمي، ويُراجع هذا السجل ربع سنوياً من قبل مسؤول النظام.
- 7.19 مشاركة المعلومات مع جهات خارجية:

- 7.19.1 يُمنع مشاركة أي وثائق إدارية أو بيانات تنظيمية مع أطراف خارجية إلا بموافقة خطية من الإدارة التنفيذية أو بموجب عقد رسمي.
- 7.19.2 يجب أن تتضمن جميع العقود مع الجهات الخارجية بنودًا صريحة حول سرية المعلومات، الامتثال للأنظمة، وحق الشركة في التدقيق والمراجعة.
- 7.19.3 تُوثق كافة عمليات المشاركة الخارجية في سجل خاص يتضمن الجهة المستفيدة، نوع البيانات، سبب المشاركة، وتاريخ الموافقة.
- 7.19.4 يجب التأكد من أن الجهة المستلمة للمعلومات تمتلك وسائل حماية مناسبة وتوقع على نموذج تعهد بالسرية.
- 7.20 إدارة الوثائق الورقية:
- 7.20.1 تُحفظ الوثائق الورقية الإدارية في خزائن مؤمنة داخل مقرات الشركة وتكون مزودة بأقفال ومراقبة مرئية إن أمكن.
- 7.20.2 يُمنع إخراج الملفات الورقية الإدارية من مقر الشركة إلا بتصريح رسمي، ويجب إعادة تسليمها خلال نفس يوم العمل.
- 7.20.3 تُحدد مدة الاحتفاظ بكل نوع من أنواع الوثائق الورقية بناءً على "جدول الاحتفاظ والإتلاف" المعتمد من إدارة الامتثال.
- 7.20.4 عند انتهاء مدة الاحتفاظ، يجب إتلاف الوثائق باستخدام آلية تقطيع (Shredder) أو عبر مزود خدمة معتمد لتدمير الوثائق، مع إصدار محضر إتلاف موقع من شاهدين.
- 7.21 الاستخدام الشخصي وغير المتعلق بالعمل:
- 7.21.1 يُسمح باستخدام المحدود لشبكة الإنترنت والبريد الإلكتروني لأغراض شخصية أثناء فترات الراحة أو خارج أوقات العمل، شريطة ألا يؤثر ذلك على أداء الموظف أو أداء الشبكة أو يتعارض مع أنظمة الشركة.
- 7.21.2 يُمنع استخدام الإنترنت أو البريد الإلكتروني الشخصي لتصفح مواقع ترفيهية، ألعاب إلكترونية، أو خدمات بث مباشر أثناء ساعات العمل الرسمية.
- 7.21.3 تُسجل جميع الاستخدامات تلقائيًا، ولا تتحمل إدارة تقنية المعلومات مسؤولية التمييز بين الاستخدام المهني والشخصي، ويُحتمل الموظف المسؤولية الكاملة عن أي استخدام مخالف.
- 7.22 حظر استخدام المدونات ووسائل التواصل الاجتماعي الشخصية:
- 7.22.1 يُمنع على الموظفين استخدام منصات النشر الإلكتروني مثل المدونات الشخصية أو وسائل التواصل الاجتماعي (Twitter، Instagram، TikTok، وغيرها) أثناء ساعات العمل أو من خلال أجهزة الشركة.
- 7.22.2 يُمنع نشر أي محتوى متعلق بالشركة أو عملها أو موظفيها على أي منصة خارجية دون تصريح رسمي.
- 7.22.3 تُعد أي مشاركة أو تعليق يحمل اسم الشركة أو يشير إليها بشكل مباشر أو غير مباشر دون تفويض، مخالفة صريحة للسياسة تستوجب التحقيق والمساءلة.
- 7.23 حقوق النشر والملكية الفكرية:
- 7.23.1 يُمنع تحميل أو استخدام أو نسخ أي محتوى خاضع لحقوق نشر أو ملكية فكرية تعود لطرف ثالث، دون الحصول على إذن كتابي مسبق من الجهة المالكة.
- 7.23.2 يُسمح بتحميل نسخة واحدة من المواد المحمية لغرض الاستخدام الداخلي أو البحثي فقط، مع الالتزام الصارم بشروط الترخيص.
- 7.23.3 تُحمل الشركة الموظف المسؤولية القانونية الكاملة في حال انتهاك حقوق النشر، وتحفظ بحقها في اتخاذ إجراءات داخلية تأديبية موازية.
- 7.24 التعهد والاعتماد:
- 7.24.1 يُلزم كل موظف ممنوح له صلاحية استخدام الأنظمة التقنية، الإنترنت، أو البريد الإلكتروني، بالتوقيع على نموذج تعهد رسمي بالاطلاع الكامل على هذه السياسة والالتزام التام بها.
- 7.24.2 يُحتفظ بنسخة من التعهد في الملف الوظيفي للموظف لدى إدارة الموارد البشرية، وترسل نسخة إلكترونية إلى إدارة تقنية المعلومات للأرشفة.
- 7.24.3 يُمنع منح أي صلاحية تقنية قبل توقيع هذا التعهد واعتماده رسميًا.
- 7.25 التحسين المستمر ومراقبة الأداء:
- 7.25.1 تُجري إدارة تقنية المعلومات مراجعات داخلية نصف سنوية لتقييم كفاءة الأنظمة، مستوى الامتثال، والجاهزية التقنية.
- 7.25.2 تُعد تقارير تحسين تقني تتضمن التوصيات والمبادرات المقترحة، وتُرفع إلى الإدارة التنفيذية للاعتماد والتنفيذ.
- 7.25.3 يُحفز الموظفون على تقديم اقتراحات تطويرية، ويُخصص بريد داخلي أو نموذج إلكتروني لاستقبالها.

7.26 حماية البيانات الشخصية:

- 7.26.1 تلتزم الشركة بتطبيق متطلبات نظام حماية البيانات الشخصية الصادر عن سدايا، واللائحة التنفيذية ذات العلاقة.
- 7.26.2 يُمنع تخزين أو معالجة أي بيانات شخصية (مثل رقم الهوية أو رقم الجوال أو بيانات العميل) إلا ضمن أنظمة معتمدة ومحمية.
- 7.26.3 يُلزم المسؤول عن النظام بتوثيق الغرض من جمع البيانات، فترة الاحتفاظ، وأذونات المعالجة، وفقاً لمبدأ "الحد الأدنى من البيانات".
- 7.26.4 تُبلغ أي حالات خرق لبيانات شخصية إلى الهيئة المختصة خلال 72 ساعة من اكتشافها، حسب ما تنص عليه اللائحة.

7.27 إدارة الأجهزة المحمولة التابعة للشركة:

- 7.27.1 تُسلم الأجهزة المحمولة (مثل اللابتوبات، الجوال، أو أجهزة البصمة والكاميرات) للموظفين بموجب نموذج استلام عهدة.
- 7.27.2 يجب تأمين الجهاز باستخدام قفل تلقائي، وبرمجيات حماية معتمدة.
- 7.27.3 يُمنع تثبيت برامج شخصية أو نسخ بيانات الشركة إلى وسائط خارجية دون موافقة مسبقة.
- 7.27.4 تُراجع الأجهزة بشكل دوري كل 6 أشهر، ويُرفع تقرير بالمخالفات أو الأعطال إلى إدارة تقنية المعلومات.

8. مسؤولية السياسة:

8.1 إدارة تقنية المعلومات:

- 8.1.1 مسؤولون عن التنسيق مع الإدارات المعنية لضمان تكامل البيانات، حماية الأنظمة، وتحديث السجلات.
- 8.1.2 مسؤولون عن قيادة جهود التوعية والتدريب لجميع الموظفين حول آليات استخدام الأنظمة، حماية البيانات، والإبلاغ عن الحوادث.
- 8.1.3 مسؤولون عن رصد الأداء والامتثال عبر مراجعات دورية، ورفع تقارير تحليلية إلى الإدارة العليا.
- 8.1.4 مسؤولون عن إدارة البلاغات الفنية والحوادث السيبرانية، بالتعاون مع إدارة الأمن السيبراني.
- 8.1.5 مسؤولون عن اعتماد الأنظمة والمزودين التقنيين الخارجيين، وضبط معايير الدخول والصيانة والدعم الفني.
- 8.2 قسم الأمن السيبراني:
- 8.2.1 مسؤولون عن تقييم المخاطر التقنية، إعداد تقارير الامتثال، ومراقبة النشاطات المشبوهة، ويُطلب من جميع الإدارات التشغيلية والمساندة الالتزام الكامل بتطبيق الضوابط المحددة في هذه السياسة، والتنسيق المستمر مع تقنية المعلومات لضمان حماية المعلومات الإدارية.
- 8.3 إدارة الجودة والتطوير:
- 8.3.1 مسؤولون عن التأكد من تطبيق هذه السياسات من خلال التدقيق والمراجعة الدورية.

9. التعاميم والتعليمات ذات العلاقة:

- 9.1 التأكيد على الالتزام بالتعليمات الخاصة بحماية البيانات الشخصية، الصادرة عن البنك المركزي السعودي، برقم (44043873)، بتاريخ 18/12/2024م.
- 9.2 أي تعاميم تخص السياسة من الجهات المشرفة.

10. حفظ السياسة:

- 10.1 تحفظ النسخة الإلكترونية الغير قابلة للنسخ من السياسة المعتمدة على نظام الموارد البشرية ويطلع عليها الإدارات ذات العلاقة.
- 10.2 تحفظ النسخة الورقية من السياسة المعتمدة في إدارة الجودة والتطوير حسب المدة النظامية المحددة في كتيب تقاؤم المستندات ترحل نظامياً إلى حفظ المستندات.

11. مخالفة السياسة:

- 11.1 يُطبق في حق المخالف لهذه السياسة ماورد في لائحة جزاءات شركة داي몬드 المعتمدة.

Diamond Insurance Broker

Information Technology Management

May 2025

Registered Name: Diamond Insurance Broker Company

Head Office: Al Thumama Road, Al Rabie District, Riyadh

Document Owner: Quality & Development Manager

Internal

DO NOT COPY



Translation

Contents	
1	Introduction.....
2	Policy Objective.....
3	Definitions.....
4	Scope of Application.....
5	Related Management and Sectors.....
6	Related Entity.....
7	General Rules.....
8	Policy Responsibility.....
9	Related Circulars and Instructions.....
10	Policy Retention.....
11	Policy Violation.....



إدارة الجودة والتطوير Quality & Development Management

Article (1): This document and the information it contains are related to Al Wathiq Al Massiya Insurance Broker (Diamond). They may not be used, copied, or disclosed, in whole or in part, to any third party without the prior written consent of Diamond. This restricted notice may not be altered or removed from this document under any circumstances.

Article (2): In the event of any discrepancy between the Arabic and English texts, the Arabic text shall prevail.

Policy Information				
Policy Title	Information Technology Management			
Policy Status	Newly Issued			
Previous Policy Title	None			
Previous Policy Date	None			
Document Number	1ITM0002			
Next Review Date	Two years from the date of policy approval or as required			
Policy Owner	Information Technology Management			
Prepared by	Quality & Development Management			
Managements/Functions that Reviewed and Approved the Policy				
Management	Position	Name	Date	Signature
Regulatory Management	Legal and Compliance Manager	Turki Abdullah Al-Abdali	29/07/2025	
Policy Review Lead	Quality & Development Manager	Shaden Sultan Alotaibi	29/07/2025	
Policy Approval				
Senior Management	Managing Director	Badr Saad Al Shaya	29/07/2025	
Document Type	Document Number	Document Title	Circulation Status	
Form	1QDM-FRM-80	External Information Sharing Record Form	Internal	

إدارة الجودة والتطوير
Quality & Development Management

1. Introduction:

1.1 The Information Technology Management Policy is an essential part of supporting the company's operations, achieving operational efficiency, and ensuring business continuity. With the rapid development of digital challenges and technological risks, it has become necessary to adopt a comprehensive IT management policy that governs all aspects related to infrastructure, information security, software, hardware, technical services, and access management—ensuring governance, protection, and regulatory compliance.

2. Policy Objective:

- 2.1 Al Wathiqah Al Massiya Insurance Broker Company (hereinafter referred to as "Diamond") affirms that the objective of this policy is to establish a regulatory and procedural framework for managing all IT activities within the company. This includes defining roles, distributing responsibilities, and applying necessary technical and security controls to ensure system integrity, data confidentiality, the reliability of technical operations, and the company's compliance with the regulations issued by the relevant regulatory authorities.
- 2.2 The policy also aims to ensure the optimal use of technological resources and to achieve the highest levels of efficiency, quality, and service continuity.

3. Definitions

- 3.1 **Diamond:** Diamond Insurance Broker.
- 3.2 **The Company:** Diamond Insurance Brokerage Company, including all its branches and affiliated entities.
- 3.3 **IT Department:** The department responsible for planning, implementing, maintaining, and operating the company's digital infrastructure and ensuring the security and efficiency of the systems in use.
- 3.4 **Technical Infrastructure:** Includes all servers, networks, computers, communication equipment, and data center facilities used to operate the company's systems.
- 3.5 **Technical Asset:** Any device or technological tool used within the work environment as part of the information systems, including computers, printers, biometric devices, cameras, servers, and routers.
- 3.6 **Technical Asset Register:** A centralized database that contains up-to-date and detailed information about all technology assets owned by the company.
- 3.7 **Administrative Software:** All programs and technical applications used to operate and manage administrative processes within the company, whether developed internally or provided by a third party.
- 3.8 **Software Compliance:** The commitment to using only licensed and approved software, in accordance with technical and regulatory requirements.
- 3.9 **Network Access Control (NAC):** A technical mechanism that prevents any unauthorized device from connecting to the company's network.
- 3.10 **Security Systems (SIEM / IDS):** Monitoring and analysis systems that log and detect suspicious activities within the technical network.
- 3.11 **Backup:** The process of periodically copying data and information to retain a secure copy for retrieval in case of malfunction or loss of original data.
- 3.12 **Encryption:** A protection mechanism used to convert data into an unreadable format except by authorized parties, using algorithms such as AES-256.
- 3.13 **Two-Factor Authentication (2FA):** A security method that requires two steps to verify a user's identity, such as a password and a temporary mobile code.

- 3.14 **Security Incident:** Any abnormal activity or breach that threatens the confidentiality, integrity, or availability of administrative information, such as leakage, unauthorized modification, or hacking.
- 3.15 **DMS:** The company's approved Document Management System used for documenting and archiving official documents and records.
- 3.16 **BCP / DRP:** The company's Business Continuity Plan and Disaster Recovery Plan, designed to ensure operational continuity in the event of emergencies or disasters.
- 3.17 **Information Owner:** The person or entity officially authorized within each department to classify, protect, and approve the sharing of information.
- 3.18 **End User:** Any employee or collaborator authorized to use the company's IT systems and devices to perform their job duties.
- 3.19 **External IT Provider:** Any third-party entity that provides technical services to the company under a formal agreement.
- 3.20 **Administrative Information:** All digital or physical data, records, and documents resulting from the company's daily operations.
- 3.21 **Personal Data:** Any information that can identify a specific individual, such as name, national ID number, mobile number, or email address.
- 3.22 **Regulatory Frameworks:** Includes regulations issued by the Insurance Authority, the Communications and Information Technology Commission (CITC), the Saudi Data and Artificial Intelligence Authority (SDAIA), the National Cybersecurity Authority (NCA), and other official regulatory bodies.
4. **Scope of Application:**
- 4.1 This policy applies to all information technology systems and assets within the company, including all devices, servers, networks, software, communication systems, email, technical accounts, and authorized users. It also applies to all employees and service providers interacting with the technical environment.
5. **Related Management and Sectors:**
- 5.1 This policy involves the IT Department, Cybersecurity Department, Compliance Department, Quality and Development Department, Human Resources Department, and all operational departments that rely on technical systems in the performance of their duties.
6. **Related Entities:**
- 6.1 All entities are fully owned by Diamond.
- 6.2 Regulatory bodies overseeing the sector (e.g., Insurance Authority, National Cybersecurity Authority).

7. General Rules:

7.1 Infrastructure and Technical Asset Management:

- 7.1.1 All devices and servers used to store or process administrative information must be purchased from authorized vendors and must meet the minimum technical specifications approved by the company.
- 7.1.2 Each technical asset must be recorded in the Technical Asset Register. The record must include: serial number, category, model, owning department, actual user, date of receipt, and current location.
- 7.1.3 The asset register must be updated at least every six months. Any transfer, loss, or malfunction must be reported immediately.
- 7.1.4 All data must be completely wiped using approved tools before disposing of any technical asset. Disposal is only allowed through a licensed entity, in accordance with environmental and regulatory policies.
- 7.1.5 All asset transfers or movements must be documented in a separate movement log, including details of the receiving party, asset condition, date, and the names of both the handing over and receiving personnel.

7.2 Networks and Communications:

- 7.2.1 Connecting additional devices, creating sub-networks, or setting up access points is strictly prohibited without written approval from the IT Director.
- 7.2.2 Continuous network monitoring systems (such as NAC / IDS / SIEM) must be activated to detect any abnormal activity or unauthorized device.
- 7.2.3 Network access logs must be retained for no less than 12 months and protected from deletion or tampering.
- 7.2.4 Internal network classification (e.g., Open Network, Restricted Network, Sensitive Network) must be implemented, with access privileges defined based on the principle of least privilege.
- 7.2.5 Use of a Network Access Control (NAC) system is mandatory to block any device not pre-registered in the approved asset list.

7.3 Administrative Software and Applications:

- 7.3.1 No application or software may be installed or downloaded without prior written approval from the IT Director.
- 7.3.2 All administrative software must be licensed and documented in the Software License Register, including purchase date, license period, provider name, and upcoming renewal date.

7.4 User Accounts and Access Privileges:

- 7.4.1 Each employee interacting with administrative information systems must be assigned a unique user account, directly linked to the approved access control directory.
- 7.4.2 User access privileges must be reviewed and updated every three (3) months in coordination between Human Resources and the IT Department.
- 7.4.3 Access rights must be revoked or suspended immediately upon termination of an employee's relationship with the company or change in their job role. No inactive account may remain active for more than 30 days without official justification.

7.5 Email and Internet Security:

- 7.5.1 Only official corporate email must be used for business purposes. It is prohibited to use it for registration in unauthorized external services.
- 7.5.2 Email and internet usage shall be monitored via intelligent security systems, and monthly reports must be generated analyzing suspicious activities.
- 7.5.3 Suspicious emails or phishing attempts must be reported immediately to the IT support team. Users are prohibited from opening attachments from unknown sources.

7.6 Backup and Data Recovery:

- 7.6.1 A regular backup schedule must be implemented for all electronic administrative data stored on the company's servers, with at least daily frequency.
- 7.6.2 Backups must be stored in a separate and secure location, taking into account environmental protection systems (temperature, humidity, fire prevention).
- 7.6.3 All backups must be encrypted using strong encryption algorithms (at least AES-256) to ensure protection from unauthorized access.
- 7.6.4 Data restoration capabilities from backups must be tested monthly to ensure system readiness during emergencies.
- 7.6.5 Use of portable external media (e.g., USB drives) for backups is prohibited unless strictly necessary and approved in writing by the IT Supervisor.
- 7.6.6 The backup plan must include official emails, meeting minutes, top management decisions, and administrative databases.

7.7 Official Email Protection:

- 7.7.1 Official email addresses (@dib.sa) must only be used for professional purposes related to administrative work.
- 7.7.2 Content of official emails must not be shared with external parties without prior approval from the information owner.
- 7.7.3 Official email must not be used to register on websites or services unrelated to the company's interests.
- 7.7.4 Two-Factor Authentication (2FA) must be enabled for all official email accounts.
- 7.7.5 Email login logs must be reviewed monthly by the Cybersecurity Officer, and any suspicious access attempt must be documented.

7.8 Management of Information Security Incidents:

- 7.8.1 Any loss, leak, unauthorized modification, or suspected breach of administrative information must be reported within one (1) hour of discovery.
- 7.8.2 Employees are required to submit an official incident report through the internal incident management system, specifying the type, location, and time of the incident.
- 7.8.3 Root cause analysis reports must be prepared by the Cybersecurity Officer in coordination with the information-owning department and submitted to executive management within 48 hours.
- 7.8.4 Incident records must be stored in encrypted format in the cybersecurity archive for no less than five (5) years.
- 7.8.5 Biannual simulation drills must be conducted to test the company's preparedness for administrative information incidents.

7.9 Documentation and Archiving:

- 7.9.1 All departments must document incoming and outgoing administrative information using the approved Document Management System (DMS).
- 7.9.2 Key administrative documents such as meeting minutes, official correspondence, management decisions, and work plans must be stored in clearly labeled folders with approved dates.
- 7.9.3 Retention periods are determined by document type:
 - 7.9.3.1 Regulatory Documents: 10 years
 - 7.9.3.2 Operational Correspondence: 5 years
 - 7.9.3.3 Daily Forms: 2 years

- 7.9.4 It is strictly prohibited to delete or destroy any administrative document before the end of its retention period unless formally approved in writing by both the IT Director and the concerned department manager.
- 7.9.5 Document destruction must be carried out electronically using secure deletion tools and recorded in the administrative destruction log.
- 7.10 Training and Awareness:
- 7.10.1 The IT Department, in collaboration with HR, must conduct regular awareness programs to educate employees on their responsibilities regarding administrative information protection.
- 7.10.2 A mandatory orientation session must be held for all newly hired employees, including detailed guidance on policies related to document and information handling.
- 7.10.3 Internal workshops must be held semi-annually covering at least the following topics:
- 7.10.3.1 Administrative information security
 - 7.10.3.2 Information classification methods
 - 7.10.3.3 Documentation and retention controls
 - 7.10.3.4 Incident reporting procedures
- 7.10.4 All employees must sign a written acknowledgment of having read and committed to the Administrative Information Management Policy. This acknowledgment must be stored in their HR file.
- 7.10.5 Training program effectiveness must be measured through periodic surveys, and an annual report must be prepared reflecting awareness levels and compliance rates.
- 7.11 Regulatory and Legislative Compliance:
- 7.11.1 All operations related to administrative information management must comply with the regulations issued by the following authorities:
- 7.11.1.1 Oversight and Anti-Corruption Authority
 - 7.11.1.2 Saudi Insurance Authority
 - 7.11.1.3 National Cybersecurity Authority (NCA)
 - 7.11.1.4 Communications, Space and Technology Commission (CST)
 - 7.11.1.5 SDAIA — for personal data protection
- 7.11.2 The policy must be updated immediately upon the issuance of new regulations affecting the collection, storage, or handling of administrative information.
- 7.11.3 Cybersecurity Department shall conduct annual compliance reviews and submit their recommendations to top management.
- 7.11.4 Contracts with external parties must include clear clauses on compliance with the laws and regulations applicable in the Kingdom of Saudi Arabia.
- 7.12 Integration with Technical Service Providers:
- 7.12.1 It is prohibited to use any external system or application to process or store administrative information unless officially approved by the IT Department.
- 7.12.2 All technical service providers must sign a Service Level Agreement (SLA) that includes clear clauses on data protection, availability, and response time.

- 7.12.3 Service provider contracts must be reviewed annually to ensure continued compliance with confidentiality and security requirements.
- 7.12.4 Each service provider must have an active support portal. Tickets must be tracked through an official system monitored by the IT Department.
- 7.12.5 Access permissions for vendor representatives must follow the principle of least privilege and be revoked immediately upon contract termination.

7.13 Governance and Accountability:

- 7.13.1 Each department must designate "Administrative Information Owners" responsible for classifying, reviewing, and approving the circulation of documents issued by their department.
- 7.13.2 The information owner must notify the IT Department of any change in the confidentiality level or scope of use of the information.
- 7.13.3 The IT Supervisor must conduct a quarterly review of access and modification logs for sensitive administrative documents.
- 7.13.4 The Cybersecurity Department shall prepare regular compliance reports, including adherence rates, identified vulnerabilities, and user behavior, to be presented to the Information Security Committee.
- 7.13.5 Strict disciplinary measures shall be applied to any employee proven to have been negligent or responsible for violating this policy, in accordance with the company's internal regulations and disciplinary procedures.

7.14 Business Continuity and Data Recovery:

- 7.14.1 The IT Department, in coordination with the Risk Management Department, must develop a Business Continuity Plan (BCP) and a Data Recovery Plan (DRP) covering all critical administrative systems and data.
- 7.14.2 These plans must be reviewed and updated annually or whenever organizational or technical changes occur that could affect business continuity.
- 7.14.3 Simulation drills must be conducted at least twice a year to test the effectiveness of the continuity plans, and results must be documented along with corrective actions.
- 7.14.4 Updated copies of the BCP and DRP must be stored in a secure online repository and a physically secured hard copy location.

7.15 Employee Security Awareness and Training:

- 7.15.1 All employees handling administrative information are required to attend an annual training on data protection, information security, and relevant company policies.
- 7.15.2 Training must cover topics such as information confidentiality, document handling, incident reporting, and proper system usage.
- 7.15.3 The effectiveness of training shall be assessed through a post-training knowledge test, and results must be documented.
- 7.15.4 The IT Department must organize quarterly awareness campaigns through email bulletins, internal posters, or short workshops.

7.16 Management of Official Forms and Documents



- 7.16.1 All administrative forms used within the company must be officially approved by executive management and updated based on operational needs.
- 7.16.2 All forms must be assigned unique identification codes and maintained in electronic format within the approved Document Management System (DMS).
- 7.16.3 The use of unapproved or outdated forms is strictly prohibited, and any employee doing so shall be held accountable.
- 7.16.4 Approved forms must be reviewed annually to ensure alignment with any operational or regulatory changes.

7.17 Compliance Monitoring and Periodic Auditing:

- 7.17.1 The Cybersecurity Department, in cooperation with the IT Department, must conduct quarterly audits to assess compliance with the Administrative Information Management Policy.
- 7.17.2 A detailed audit report must be prepared, including identified gaps, violations, and recommended improvements, and submitted to the CEO.
- 7.17.3 Audit reports must be stored in the compliance log and reviewed by the Risk and Compliance Department.
- 7.17.4 Each department must submit a corrective action plan for any recorded violations within 15 days of receiving the audit report.

7.18 Employee Offboarding and Transfers:

- 7.18.1 The Human Resources Department must notify the IT Department at least three (3) business days prior to the termination or transfer of any employee.
- 7.18.2 All system and file access privileges, including user accounts, email, and document systems, must be revoked on the employee's final working day.
- 7.18.3 In case of departmental transfers, access privileges must be reassessed according to the new role, and updates must be documented in the access management log.
- 7.18.4 All actions related to privilege revocation or modification must be recorded in an official log, which shall be reviewed quarterly by the system administrator.

7.19 Information Sharing with External Parties:

- 7.19.1 No administrative documents or regulatory data may be shared with external parties without written approval from Executive Management or under a formal contract.
- 7.19.2 All contracts with external entities must explicitly include clauses on data confidentiality, regulatory compliance, and the company's right to audit and review.
- 7.19.3 All external information-sharing activities must be documented in a dedicated log including the recipient entity, type of data shared, reason for sharing, and approval date.
- 7.19.4 The receiving party must have adequate protection mechanisms in place and must sign a confidentiality agreement.

7.20 Management of Physical Documents:

- 7.20.1 Physical administrative documents must be stored in secure cabinets within company premises, preferably with locks and visual surveillance.
- 7.20.2 Physical files may not be removed from the company premises without an official permit, and must be returned on the same business day.
- 7.20.3 Retention periods for all types of paper documents shall be determined based on the "Retention and Disposal Schedule" approved by the Compliance Department.
- 7.20.4 Upon expiration of the retention period, documents must be shredded using a secure method or destroyed via an approved vendor, with a signed destruction report by two witnesses.
- 7.21 Personal and Non-Work-Related Use:
- 7.21.1 Limited personal use of internet and email is permitted during break times or outside working hours, provided it does not impact employee performance, network integrity, or violate company policies.
- 7.21.2 Use of internet or personal email for entertainment, online gaming, or live streaming during official working hours is prohibited.
- 7.21.3 All usage is automatically logged. The IT Department shall not be held responsible for distinguishing between professional and personal use. The employee is fully accountable for any misuse.
- 7.22 Use of Personal Blogs and Social Media:
- 7.22.1 Employees are prohibited from using personal blogging platforms or social media (Twitter, TikTok, Instagram, etc.) during work hours or through company devices.
- 7.22.2 Publishing any content related to the company, its operations, or its employees on any external platform without official authorization is strictly prohibited.
- 7.22.3 Any mention or reference to the company, directly or indirectly, without authorization is considered a policy violation and will be subject to investigation and disciplinary action.
- 7.23 Copyright and Intellectual Property:
- 7.23.1 Downloading, using, or copying any third-party copyrighted or proprietary content is prohibited without prior written permission from the copyright holder.
- 7.23.2 One copy of protected content may be downloaded for internal or research purposes only, subject to strict compliance with license terms.
- 7.23.3 The employee will bear full legal responsibility for copyright infringement, and the company reserves the right to apply parallel internal disciplinary actions.
- 7.24 Declaration and Policy Acknowledgement:
- 7.24.1 All employees granted access to company systems, internet, or email must sign an official declaration confirming full awareness of and compliance with this policy.
- 7.24.2 A signed copy of the declaration must be stored in the employee's HR file, and a digital copy sent to the IT Department for archiving.
- 7.24.3 No access privileges shall be granted before the declaration is duly signed and approved.
- 7.25 Continuous Improvement and Performance Monitoring:

- 7.25.1 The IT Department shall conduct internal semi-annual reviews to assess system efficiency, compliance levels, and technical readiness.
- 7.25.2 Technical improvement reports including recommendations and proposed initiatives must be submitted to Executive Management for approval and implementation.
- 7.25.3 Employees are encouraged to submit improvement suggestions via an internal email or designated electronic form.

7.26 Personal Data Protection:

- 7.26.1 The company is committed to implementing the requirements of the Personal Data Protection Law issued by the Saudi Data and AI Authority (SDAIA), along with its related executive regulations.
- 7.26.2 Storing or processing any personal data (such as ID numbers, mobile numbers, or customer data) is strictly prohibited outside approved and secure systems.
- 7.26.3 System owners must document the purpose of data collection, retention period, and processing permissions, in accordance with the "minimum data principle."
- 7.26.4 Any personal data breach must be reported to the competent authority within 72 hours of detection, as stipulated by applicable regulations.

7.27 Management of Company-Issued Mobile Devices:

- 7.27.1 Mobile devices (e.g., laptops, mobile phones, biometric devices, or cameras) must be issued to employees under a signed custody form.
- 7.27.2 Devices must be secured using automatic locks and approved security software.
- 7.27.3 Installing personal software or copying company data to external media is prohibited without prior approval.
- 7.27.4 All devices shall be reviewed biannually, and a report of violations or malfunctions submitted to the IT Department.

8. Policy Responsibilities

8.1 Information Technology Management:

- 8.1.1 Responsible for coordinating with relevant departments to ensure data integrity, system protection, and record updates.
- 8.1.2 Responsible for leading awareness and training efforts for all employees on system usage, data protection, and incident reporting.
- 8.1.3 Responsible for monitoring performance and compliance through periodic reviews and reporting to senior management.
- 8.1.4 Responsible for managing technical incidents and cybersecurity events in coordination with the Cybersecurity Department.
- 8.1.5 Responsible for approving external systems and technical vendors, and controlling access, maintenance, and support standards.

8.2 Cybersecurity Department:

- 8.2.1 Responsible for assessing technical risks, preparing compliance reports, and monitoring suspicious activity
All operational and support departments are required to fully comply with the controls specified in this policy and maintain ongoing coordination with IT to ensure protection of administrative information

8.3 Quality and Development Management:

- 8.3.1 Responsible for ensuring the implementation of this policy through regular audits and reviews.

9. Related Circulars and Regulations:

- 9.1 Mandatory adherence to the Personal Data Protection circular issued by the Saudi Central Bank (No. 44043873), dated 2024-12-18.
- 9.2 Any future regulatory circulars related to this policy issued by authorized regulators.

10. Policy Retention:

- 10.1 The non-copyable digital version of the approved policy shall be stored in the HR system and made accessible to relevant departments.
- 10.2 A hard copy of the approved policy shall be retained by the Quality and Development Department for the legally defined retention period as specified in the Document Aging Manual and then formally archived.

11. Policy Violation:

- 11.1 Any violation of this policy shall be subject to the penalties outlined in Diamond's approved Disciplinary Regulations.